

システム基盤構成概要書

1. 文書管理

本文書は当行のシステム基盤構成に関する概要を記載した技術文書である。文書番号 INFRA-2024-001、バージョン 2.5、最終改訂日 2024年10月1日とする。管理責任者はシステム統括部基盤管理課長とし、改訂時には運用部門長の承認を必要とする。

配布先はシステム部門、リスク管理部門、および内部監査部門とし、社外秘として取り扱う。改訂履歴はすべて文書管理システム (SharePoint) にて管理し、旧版は改訂日から5年間保管する。FISC安全対策基準 技-1 (システム構成管理) に準拠し、年次で見直しを実施する。

本書の適用範囲は、勘定系システム、情報系システム、チャネル系システム (インターネットバンキング・モバイルバンキング)、および対外接続系システムを含む全行システム基盤とする。クラウドサービス利用部分についてもFISC安全対策基準 技-40 (外部委託先管理) に基づき本書にて管理対象とする。

2. 全体構成概要

当行のシステム基盤は、ハイブリッドクラウドアーキテクチャを採用している。オンプレミス環境として東京データセンター (東京DC：品川) を主系、大阪データセンター (大阪DC：堂島) をDR系として配置し、パブリッククラウドとしてAWS東京リージョン (ap-northeast-1) を活用している。勘定系システムは東京DCオンプレミスに配置し、情報系およびチャネル系はAWSとのハイブリッド構成とする。

東京DCと大阪DC間はNTTコミュニケーションズ提供の専用線 (10Gbps x 2本、冗長構成) で接続し、データ同期レプリケーションを実施している。東京DCとAWS間はAWS Direct Connect (10Gbps) を2本敷設し、BGPによるアクティブ・スタンバイ構成とする。AWS側のVPCはTransit Gatewayを用いて集約管理し、環境別 (本番・ステージング・開発) にアカウント分離を行っている。

全体のシステム可用性目標は、勘定系99.99% (年間ダウンタイム52分以内)、チャネル系99.95% (年間ダウンタイム4.4時間以内) と定める。これらの目標値はFISC安全対策基準 技-2 (可用性確保) に基づき設定し、月次でSLA達成状況をレビューする。

3. ネットワークトポロジー

インターネット接続はISP冗長構成 (NTTコミュニケーションズ / KDDI) とし、各ISPからBGPフルルートを受信するマルチホーム接続を採用している。上流帯域は各ISPあたり10Gbps契約 (バースト20Gbps対応) とし、通常時のトラフィックピークは3Gbps程度である。DDoS対策としてISP側にてFlowspec制御を設定し、当行側ではArbor Networks AEDを導入している。

社内ネットワークはセグメント分離を徹底しており、DMZ (203.0.113.0/24)、フロントセグメント (10.1.0.0/16)、アプリケーションセグメント (10.2.0.0/16)、データベースセグメント (10.3.0.0/16)、管理セグメント (10.254.0.0/16) の5層構成とする。各セグメント間はPalo Alto PA-5260ファイアウォールにてマイクロセグメンテーションを実施し、最小権限の原則に基づいたアク

セス制御リスト (ACL) を適用している。

拠点間接続はIP-VPN (KDDI Wide Area Virtual Switch 2、帯域100Mbps〜1Gbps) を利用し、本店・支店間の業務通信を処理する。リモートアクセスVPNはPalo Alto GlobalProtectを採用し、クライアント証明書 + LDAP認証による二要素認証を必須とする。VPN接続時はスプリットトンネルを禁止し、全トラフィックをDCゲートウェイ経由とする。

AWS VPC内のネットワーク構成は、パブリックサブネット (ALB/NAT Gateway配置)、プライベートサブネット (アプリケーション配置)、データサブネット (RDS/ElastiCache配置) の3層とし、各AZ (ap-northeast-1a / 1c / 1d) に冗長配置する。Security Groupは用途別に定義し、NACLはサブネット単位でステートレスフィルタを適用する。

4. オンプレミスデータセンター

東京DCは品川エリアのティア3+相当データセンター (NTTコミュニケーションズ運営) に設置している。当行専用のサーバールームとして2フロア (計400ラック分) を契約し、現在約280ラックを使用中である。電源はA系統・B系統の二重受電方式で、各系統は独立したUPS (Eaton 9395P 600kVA x 4台) により無停電化を実現している。

空調設備はコールドアイル封じ込め方式を採用し、インラック型精密空調 (Vertiv Liebert DSE) にて1ラックあたり最大15kWの冷却能力を確保する。温度は $22\pm 2^{\circ}\text{C}$ 、湿度は $45\pm 10\%\text{RH}$ に維持し、環境センサーにより常時モニタリングを行っている。FISC安全対策基準設-2 (電源設備) および設-3 (空調設備) の要件を満たす構成である。

自家発電設備はディーゼル発電機 (2,000kVA x 2台) を屋上に設置し、72時間の連続運転が可能な燃料備蓄を確保している。商用電源停電時はUPSが即時バッテリー給電に切り替わり、30秒以内に自家発が起動・並列投入される。年2回の自家発起動試験および負荷試験を実施し、結果を設備管理台帳に記録する。

5. クラウド構成 (AWS)

チャネル系システム (インターネットバンキング) のWebフロントエンドおよびAPIゲートウェイはAWS上に構築している。EC2 Auto Scaling Groupにより、通常時4台〜ピーク時16台 (c6i.2xlarge) の範囲で自動スケーリングを行い、CPU使用率70%を閾値としたターゲットトラッキングポリシーを設定する。月末・給与日のトラフィック急増にも自動対応可能な構成とする。

コンテナ基盤としてAmazon ECS Fargateを採用し、マイクロサービス群 (認証サービス・残高照会サービス・振込サービス等12サービス) をデプロイしている。各サービスのコンテナイメージはAmazon ECRに格納し、脆弱性スキャン (ECR Image Scanning + Trivy) をCI/CDパイプラインに組み込んでいる。Fargateタスクには最小権限のIAMロールを付与し、タスク間通信はAWS App Meshにて暗号化する。

データ層はAmazon RDS for PostgreSQL 15 (Multi-AZ構成、db.r6g.2xlarge) を利用し、読み取り負荷分散用にリードレプリカを2台配置する。接続プーリングはRDS Proxyを使用し、最大接続数の管理を効率化している。データ暗号化はAWS KMS管理キー (CMK) による透過的暗号化 (TDE) を適用し、FISC安全対策基準技-18 (データ暗号化) の要件を充足する。

静的コンテンツ配信はAmazon S3 + CloudFrontを利用する。S3バケットはバージョニング有効、パブリックアクセスブロック適用、SSE-KMS暗号化を設定する。CloudFrontにはAWS WAFを関

連付け、OWASPルールセットおよびカスタムレートリミット（同一IPから1,000リクエスト/5分）を適用している。

6. サーバ構成

Webサーバ層はNginx

1.26（オンプレミス4台、Active-Active構成）を配置し、L7ロードバランサ（F5 BIG-IP i5800）によるラウンドロビン分散を行う。NginxにはリバースプロキシS設定を適用し、バックエンドのアプリケーションサーバへHTTP/2でリクエストを転送する。SSL/TLS終端はF5 BIG-IPにて行い、TLS 1.3を標準、TLS 1.2を最低バージョンとして構成する。

アプリケーション層はKubernetes 1.29クラスタ（オンプレミス3ノード、各ノード: Intel Xeon Gold 6348 28コア / 256GB RAM / NVMe SSD 1TB x 2

RAID1）上に構築する。コントロールプレーンはHA構成（etcd 3台）とし、ワーカーノードは通常3台〜最大6台のCluster Autoscalerを構成する。ネットワークプラグインはCalicoを採用し、NetworkPolicyによるPod間通信制御を実装している。

データベース層はPostgreSQL 16（プライマリ1台 + 同期スタンバイ1台 + 非同期スタンバイ1台）による3ノード構成とする。プライマリ障害時は同期スタンバイが自動昇格（Patroni管理）し、RTO 30秒以内を実現する。データベースサーバのスペックはIntel Xeon Gold 6354 36コア / 512GB RAM / NVMe SSD 3.84TB x 4 RAID10であり、月末バッチピーク時のIOPS要件（50,000 IOPS）を十分に満たす。

7. ストレージ構成

オンプレミスのブロックストレージとして、Dell PowerStore 9200T（有効容量500TB、実測IOPS 200,000以上）を導入している。勘定系データベースのストレージはこのSANに格納し、FC 32Gbps x 4ポートのマルチパス接続でサーバと接続する。スナップショットは日次で取得し、30日分を保持する。

ファイル共有用のNASストレージはNetApp AFF A250（有効容量100TB）を使用し、NFSv4.1プロトコルで各サーバに接続する。帳票データ、ログファイル、およびバッチ処理の入出力ファイルはNAS上に配置する。Snapshotポリシーにより日次7世代、週次4世代、月次12世代を自動保管する。

長期保管データおよびバックアップデータはAWS S3（Standard / Glacier）に格納する。S3 Lifecycle Policyにより、90日経過データはS3 Glacier Flexible Retrieval、365日経過データはS3 Glacier Deep

Archiveに自動移行する。バックアップデータの保管期間は法令要件に基づき最長10年とし、S3 Object Lockにより改ざん防止（WORM）を適用する。

バックアップ運用はVeeam Backup & Replication 12を使用し、日次フルバックアップ（02:00開始）および1時間ごとの差分バックアップを実施する。バックアップデータはオンサイト（PowerStore スナップショット）とオフサイト（S3 + 大阪DCテープ）の3箇所に保管し、3-2-1ルールに準拠する。

8. 監視基盤

システム監視基盤はPrometheus 2.51 + Grafana 10.4 を中核とし、PagerDutyによるアラート通知を行う。Prometheusは東京DC内に冗長構成（2台）で配置し、Thanos Sidecarを用いてメトリクスの長期保管（S3、保持期間2年）を実現する。各サーバにはnode_exporter、Kubernetesにはkub-e-state-metricsをデプロイし、約3,500のメトリクスを15秒間隔で収集する。

Grafanaダッシュボードはシステム概要、サーバリソース、アプリケーションパフォーマンス、ネットワークトラフィック、セキュリティの5カテゴリに分類し、計42枚のダッシュボードを運用する。各ダッシュボードはInfrastructure as Code（Terraform + Grafana Provider）で管理し、変更時はGitHub PR経由のレビューを必須とする。

アラート閾値は以下のレベルで定義する。Warning（注意）：CPU使用率70%以上5分継続、メモリ使用率75%以上5分継続、ディスク使用率80%以上。Critical（重大）：CPU使用率90%以上3分継続、メモリ使用率90%以上3分継続、ディスク使用率90%以上、サービス無応答30秒以上。PagerDutyの通知先はWarningは運用チームSlackチャンネル、Criticalは担当者電話呼び出し（5分以内応答必須）とする。

アプリケーション監視にはNew Relic APMを導入し、トランザクションの応答時間（P95: 200ms以下、P99: 500ms以下）、エラーレート（0.1%以下）、スループット（通常時2,000 TPS、ピーク時5,000 TPS）を監視する。Syntheticsによる外形監視を1分間隔で実施し、可用性SLA達成状況を自動算出する。

9. セキュリティ機器構成

ファイアウォールはPalo Alto Networks PA-5260を東京DC・大阪DCにそれぞれHA構成（Active-Passive）で配置する。ゾーンベースポリシーにより、Untrust→DMZ→Trust間の通信をアプリケーションレベルで制御し、全通信ログをSplunkへ転送する。URLフィルタリング、アンチウイルス、アンチスパイウェア、WildFire（サンドボックス解析）のサブスクリプションを有効化し、未知の脅威にも対応する。

Web Application FirewallはAWS WAFおよびオンプレミスF5 Advanced WAF（旧ASM）を併用する。OWASPトップ10対策ルール、SQLインジェクション防御、クロスサイトスクリプティング防御に加え、ボット対策としてCAPTCHAチャレンジおよびJavaScriptチャレンジを実装する。WAFルールのチューニングは月次で実施し、誤検知率を1%以下に維持する。

侵入検知システム（IDS/IPS）はSuricata 7.0をインラインモード（IPS）で配置し、ET Proルールセットを日次で更新する。東京DC-インターネット間、DC間、およびAWS Direct Connect接続点の3箇所にセンサーを配置し、全トラフィックのディープパケットインスペクションを実施する。検知イベントはSplunkに集約し、相関分析ルールにより攻撃シナリオを自動検出する。

エンドポイントセキュリティはCrowdStrike Falcon Insightを全サーバ・端末に導入し、EDR（Endpoint Detection and Response）機能によりリアルタイムの脅威検知・対応を行う。FISC安全対策基準技-15（不正アクセス対策）および技-16（マルウェア対策）に準拠した多層防御を構成する。

10. 物理設備・環境設備

東京DCの建物は新耐震基準に適合し、免震構造（積層ゴム支承）を採用している。震度7相当の地震にも耐えうる設計であり、年次の建物点検において構造体の健全性を確認している。サーバルームの床荷重は1,500kg/m²に対応し、高密度ラック（最大20kW/ラック）の設置が可能である。

無停電電源装置（UPS）はEaton 9395P 600kVA x 4台をA系統・B系統に各2台ずつ配置し、N+1冗長構成とする。バッテリー持続時間は満充電時15分であり、自家発電機起動までの電源供給を保証する。UPSバッテリーは3年ごとに交換し、毎月のバッテリーテスト結果を設備管理台帳に記録する。

消火設備はインARGEンガス消火システム（窒素ベース不活性ガス）を採用し、煙感知器の2段階検知（第1報：予備警報、第2報：本警報+ガス放出）により誤放出を防止する。スプリンクラーはサーバールーム外の共用部に設置し、サーバールーム内は予作動式を採用して水損リスクを最小化する。消火設備の点検は消防法に基づき年2回実施する。

入退室管理は3段階の認証を実施する。建物入口で非接触ICカード、サーバールーム前室で静脈認証（富士通 PalmSecure）、ラックエリアでICカード+暗証番号の多要素認証とする。全入退室ログはSplunkに送信し、90日間のリアルタイム検索および5年間の長期保管を行う。FISC安全対策基準 設-8（入退室管理）の要件に準拠する。